IT Data Center and Facilities Management Procedure

Document Number: XYZ-TS-IS-005

Classification: Internal

Owner: Chief Digital Officer (CDO)

Effective Date: 15-Sep-2021

CS5292 W6 · D14 · sanitised for teaching

Version: 2.0

Document History:

Release Date	Revision No	Author(s)	Description	Reviewed & Approved By	Next review date
15-Sep-2021	1.0	ISO	Approved Document	ISMC	Sep-2022
05-Sep-2023	1.0	ISO	Approved Document	ISMC	Sep-2024
01-Mar-2025	2.0	ISO	Transition	ISMC	Mar-2026

CS5292 W6 · D14 · sanitised for teaching

Table of Contents

1. Introduction 4
1.1 Purpose 4
1.2 Scope 4
1.3 Responsibility 4
1.4 Laws and Regulations 4
1.5 Procedure Implementation 5
1.6 Compliance 5
1.7 Review and Revision 5
1.8 Related Documents 5
1.9 Glossary of Terms 7
1. Critical Business Information Processing Areas 10
2. Physical Access 10
2.1 Internal Staff (Permanent Employees) 10
2.2 Visitor (Contract employees, Outsourced employees, and non-XYZ Holdings staff) Access 10
2.3 Internal Non-IT Staff Access to Data Centre 10
2.4 Unsolicited Visitors 11
3. Physical Security Zones 11
4. Physical Security Controls to XYZ-TS Premises 11
5. Data Center Access (Server Room) 12
6. Monitoring of Secure Areas 13
7. Environmental protection and support utilities of the XYZ TS premises 13
8. Security of Equipment and Personnel 14
9. Main Responsibilities 15
10. Power, Air-conditioning, and Other Supporting Utilities 16
11. Cabling Security 17
12. Removal and Disposal of IT Equipment 17
13. Information Security Management System Auditor 18
14. Latest Version of This Document 18

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

1. Introduction

1.1 Purpose

The objective of the IT data center and Facilities Management procedure is to establish standardized processes to:

- Establish IT data center and Facility requirements in line with leading practices and industry-accepted standards.
- Communicate and implement IT Datacenter and Facility requirements.
- Manage and monitor such facilities to ensure safe and secure operations.
- Review humidity, ventilation, air conditioning, fire suppression, CCTV cameras, and redundant/ continuous power supplies implemented at such facilities; and
- Monitor IT data centers and Facility access controls.

1.2 Scope

The scope of the physical and environmental security procedure is limited to the physical boundaries of the XYZ Holdings premises and the physical boundaries of information processing facilities that contain information assets related to XYZ Holdings.

1.3 Responsibility

The Head of Infrastructure Services and Support shall be accountable for the effective review, approval, communication, implementation, and adoption of the IT data center and Facilities Management procedure and all changes.

The Data Center manager is responsible for the accuracy and maintenance of this procedure and its efficacious communication and implementation.

All IT Employees across XYZ Holdings shall support the effective adoption and implementation of this IT data center and Facilities Management procedure.

1.4 Laws and Regulations

This IT data center and Facilities Management procedure shall conform to the legal and regulatory requirements of [count and any other country where XYZ Holdings conducts its business operations. These include "The Computer Crimes Act 24 of 2007 of [coun and any other laws and regulations that may apply to protect the Environment and preserve individuals' rights and organizational information assets.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

1.5 Procedure Implementation

This IT data center and facilities management procedure shall be implemented by adopting, enforcing, and implementing industry-leading standards for IT data centers and IT facilities management. These would include but not be limited to ISO72001/ ISO27002 information security management system standards and guidelines related to IT data centers and IT facilities.

- Such requirements will be enforced through appropriate contracts/ agreements or service level agreements with data center service providers.
- Cloud service providers will also be selected based on their ability to confirm compliance with such standards/ requirements.

1.6 Compliance

- XYZ-TS owns the systems and services it provides. This gives XYZ-TS the right to monitor all activities performed using these resources.
- Users shall maintain continued compliance with all XYZ-TS policies, procedures, guidelines, rules, and administrative orders while using XYZ-TS systems, facilities, and/or services.
- The Chief Digital Officer shall designate persons to perform periodic reviews and provide relevant feedback on this procedure's design and operating effectiveness.
- Non-compliance with this procedure shall be recorded and responded to through the Incident and Problem Management procedure.
- If XYZ-TS discovers or has good reason to suspect activities that do not comply with applicable laws or policies, activity logs or records may be retrieved and used/ presented as evidence for disciplinary action against the involved user.

1.7 Review and Revision

This IT data center and Facilities Management procedure shall be periodically reviewed and updated to reflect changes in the organization, operating environment, local laws and regulations, technology trends, leading practices, international standards, and recommendations provided by consultants/ advisors and internal and external auditors.

The procedure review and revision period shall not exceed one Calendar year.

1.8 Related Documents

This procedure references the following documents:

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

Document Name	*Organization*	*Description*
ISO/IEC 22301:2012	International Organization for Standardization	ISO standard for business continuity management
ISO/IEC 27001:2013	International Organization for Standardization	ISO standard for information security management
TIA-942	Telecommunication Industry Association	Telecommunication Industry Association standard for data centers
COBIT5 Framework	Information Systems Audit and Control Association	A Business Framework for the Governance and Management of Enterprise IT
Acceptable Information System Usage Policy	XYZ Holdings: Technology Services	Defines requirements and expectations for acceptable usage of information systems at XYZ Holdings
Information Technology and Information Security Committees Terms of Reference	XYZ Holdings: Technology Services	Defines information technology and information security committees for XYZ Holdings, including their composition, roles, responsibilities, and authorities.
Intellectual Property Protection Policy	XYZ Holdings: Group Legal Department	Provides guidelines on the appropriate method of handling IP rights within the business.
IT Governance and Management Policy	XYZ Holdings: Technology Services	Defines requirements and expectations for governance and management of IT systems, facilities, and operations at XYZ Holdings.
XYZ Holdings Confidentiality Policy	XYZ Holdings: Group Legal Department	Defines requirements and expectations for managing and handling confidential information at XYZ Holdings.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

1.9 Glossary of Terms

This procedure uses the following terms in the given context:

Term	***Description***
Access Control	Access Control refers to controlling access to a system, location, or facility for those who need it to perform their regular job responsibilities and limiting such access to only those functions and authorities they need to carry out their duties effectively.
Availability	Availability is a characteristic of assets. An asset is available if it is accessible and usable when needed by an authorized person. Assets include information, systems, facilities, networks, and computers. All these assets must be available to authorized persons when they need to access or use them.
Confidentiality	Confidentiality is a characteristic of information. Information must not be made available or disclosed to unauthorized persons to protect and preserve confidentiality.
Datacenter	A facility or location where critical IT systems, such as servers and networking components, are maintained under proper physical and HVAC controls.
DRP	Disaster Recovery Planning (DRP) is the process of defining action plans, solutions, and work steps to recover and protect IT systems in the event of a disaster. Such a plan, ordinarily documented in written form, specifies procedures the organization is to follow in the event of a disaster.
HVAC	Humidity, Ventilation, and Air Conditioning in data centers and Information Processing facilities.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

Information Processing Facility	An Information Processing Facility can be a system, service, infrastructure, or any physical location that houses information, such as an IT Department.

Term	***Description***
Integrity	Preserving the integrity of information means protecting its accuracy and completeness and the methods used to process and manage it.
MTD	Maximum Tolerable Downtime (MTD) refers to the maximum amount of time a business or a particular service can be out of operations before the impact of an outage leads to permanent and irrecoverable damage.
High Availability	High Availability refers to a system or component that is continuously operational for a desirable length of time. In practice, high availability is achieved through designing and implementing solutions with adequate redundancy and resilience.
PSTN	Public Services Telephony Network – ie. The traditional voice telephone network.
Redundant Systems	Redundant systems are computer or network system components, such as fans, hard disk drives, servers, operating systems, switches, and telecommunication links installed to back up primary resources in case they fail.
Resilience	Hardware failures, natural disasters, and malicious attacks can cause service disruptions. Resilience is an organization's ability to maintain acceptable IT service levels.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

Risk	Combination of the probability of an unwanted event and its consequence/ impact.
Threat	A threat is a potential event that could damage, lose, or compromise IT systems or disrupt normal business operations.
Term	***Description***
UPS	Uninterruptible Power Supply – a system that regulates and improves the electrical power quality and provides continuous, high-quality electrical power in case of a sudden power failure.
Vulnerability	Vulnerability is a weakness that allows an attacker to compromise a system. It exists when a system is susceptible or flawed, the attacker has access to the flaw, and the attacker can exploit it.

CS5292 W6 · D14 · sanitised for teaching

1. Critical Business Information Processing Areas

Critical business information processing areas are defined as physical locations where specific controls are mandated by regulatory, compliance, legal, or business agreements or physical locations where "Confidential" or "Internal" information is processed on a large scale.

2. Physical Access

2.1 Internal Staff (Permanent Employees)

Upon recruitment as a XYZ-TS staff, particular personnel will receive a Company ID tag.

All the XYZ-TS internal staff are recommended to wear company-issued ID tags when entering the XYZ-TS premises.

2.2 Visitor (Contract employees, Outsourced employees, and non-XYZ Holdings staff) Access

Visitors are only allowed in the XYZ-TS reception area and the meeting rooms with proper authorization.

The XYZ will escort visitors who need to access XYZ-TS Information Processing areas–TS IT Employees after getting approval from the Manager of Infrastructure and IT Support Services.

The front desk officer will obtain the visitor's details (e.g., Name, NIC number, Company Name, entering date and time, etc.) and issue the visitor pass while confiscating the visitor's NIC. As the visitor leaves the premises, these will be exchanged again with the Receptionist/ Front Desk officer. A separate Visitor logbook will be maintained at the Reception / Front Desk to log in and out of the XYZ-TS Premises visitors.

The visitor must always wear the given Visitor Pass to gain entrance into the XYZ-TS Premises. Visitors shall always be escorted by XYZ-TS IT employees whenever they gain access to the XYZ-TS Premises.

2.3 Internal Non-IT Staff Access to Data Centre

Non-IT staff are strictly prohibited from entering the data center.

Non-IT staff who need to access the XYZ –TS Server Room for legitimate purposes will have to sign a logbook and be escorted by an Information Systems/Support/IDC team member when entering the data center.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

2.4 Unsolicited Visitors

Unsolicited visitors should usually be turned away. Under no circumstances must an unsolicited visitor be allowed access until the same approval process as mentioned in the Visitor Access section.

3. Physical Security Zones

Zone	Access Restriction	Designated Areas
Public zone	▪ No restrictions. ▪ Area under overall surveillance.	▪ Main entrance to XYZ TS ▪ Working floors ▪ Reception areas
Office zone	▪ Limited access – all unauthorized personnel must register with the security office before entry. ▪ All entrants must wear XYZ TS identity badges (employee or visitor). The employee badges must be distinct from visitor badges. ▪ Area under overall surveillance.	▪ All areas within XYZ TS premises other than the Public and Restricted Zone.
Restricted zone	▪ Specific restricted access. ▪ Area-specific access controls. ▪ All visitor access must be logged. ▪ Escorted access for visitors. ▪ Area under surveillance. ▪ All entrants must wear XYZ TS identity badges (employee or visitor)	▪ Data Centers ▪ IT room ▪ HR and Finance Department

4. Physical Security Controls to XYZ–TS Premises

Before implementation, the Head of Infrastructure and IT Support will assess any changes to the existing physical security controls.

The XYZ TS Information Security Management System Manual will control access to any information processing facility.

XYZ TS shall immediately instruct staff to report any suspicious activity within XYZ TS premises to the IT Support Help Desk. Upon receiving a notification of an information security incident from the

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

staff, an IDC team member will address the incident per the XYZ TS incident management procedure. Staff will also inform the Administration Head of other security incidents.

When visitors are provided access to XYZ TS, they will always be accompanied by a XYZ TS IDC/NOC team member. The IT risk and compliance manager will review access to the XYZ TS IT Division quarterly.

Data center access logs and registers will be reviewed quarterly by Manager Datacenter to ensure the physical security of the premises and Data Center are not compromised and that the procedure followed complies with the established procedure. Any exceptions noted will be reported to the Head of Infrastructure and Support Services.

"Restricted Zones" must be declared with clear signs (e.g., "Restricted Zone - Authorized Personnel Only").

5. Data Center Access (Server Room)

Data center access will only be granted to personnel with a clear need for such access.

A Biometric system will control data center access. The Head of Infrastructure and Support will approve the XYZ TS employees registered in this system for access.

The Manager Infrastructure will maintain an authorized list of users. The names of the approved individuals will be included in the Authorized Personnel list displayed at the entrance to the respective data center. Only authorized personnel can take any Computing Devices or removable media inside the data center.

A Support/IDC team member at XYZ TS will accompany visitors to the data center and maintain a logbook recording visitor access to the data center.

The logbook will maintain visitor details such as National ID number/passport number, date and time of entry to the data center, reason for entry, date and time of exit, and name and employee number of authorized employees escorting the visitor to the data center.
This will be reviewed by the Manager Datacenter bi-annually.
Photography, video, audio, or other recording equipment, such as cameras in mobile devices, food and beverages, hazardous materials, tools, removable storage devices, electro-magnetic devices that could unreasonably interfere with data center equipment, and footwear are not allowed in the Data Center unless the Manager Datacenter authorizes it.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

6. Monitoring of Secure Areas

Video cameras should monitor All secure areas so that the whole area is covered.

The video cameras should be configured to record movements from the time a person enters the secure area(s) where cardholder data resides until the person leaves the secure area(s).

The premises will be under continuous (24/7) video surveillance. Any observed suspicious activity or unauthorized access will be promptly reported and investigated.

The video camera coverage will be monitored from 07:00 to 19:00, and any suspicious activity or unauthorized access should be informed and investigated.

The images captured by the video cameras should be preserved for a minimum of 30 days.

In a security incident in the secure area, captured images must be copied and analyzed. This process should ensure the preservation of evidence if it is required for presentation in a court of law.

Recording and retention of closed-circuit video surveillance (CCTV) in critical business information processing areas must adhere to the requirements mandated by regulatory, compliance, legal, or business agreements. If necessary, visible warning signs indicating video recording activity should be displayed, and consent from individuals being recorded shall be obtained.

7. Environmental protection and support utilities of the XYZ TS premises

The Head of IT Infrastructure manages environmental controls and supports utilities as illustrated in Section 7.0 Main Responsibilities.

The infrastructure team member will email any new requirement for environmental controls to the Head of IT Infrastructure.

Critical business processing equipment must be protected by strategically placed and adequate fire detection and extinguishing systems that are easy to access in an emergency.

The Administration Department manages fire safety at XYZ TS by selecting and maintaining all fire detection and extinguishing equipment.

Fire detection and suppression equipment maintenance must be performed by qualified personnel at frequencies specified by the manufacturer. Clear instructions for extinguisher use should be located near each extinguisher.

Store hazardous or combustible materials away from sensitive areas like server rooms and UPS rooms. If such storage is unavoidable, maintain a safe distance and provide appropriate fire extinguishers nearby.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

All staff must be trained to use all fire extinguishing equipment. The training frequency must be at least annually.

All staff members are responsible for educating themselves on using fire equipment and fire safety procedures and must seek advice and instructions from the Administration Department whenever required.

Critical IT equipment placement should minimize the risk of water damage from floods, rain, or plumbing issues. Preventive measures include raised floors, elevated platforms, and proper building drainage systems.

Equipment should be maintained periodically according to vendor specifications and service intervals.

Equipment custodians must ensure the safety of equipment and data during maintenance work.

Records of equipment failures during maintenance should be kept, along with the remedial measures executed to rectify the failure. The records should include the names and identification of the personnel who participated in the maintenance routine.

The following table illustrates the control owners for controls related to the physical and environmental security of XYZ TS premises.

The Administration Department shall maintain and review separate maintenance logbooks for each service, documenting the service performed and its maintenance schedule.

8. Security of Equipment and Personnel

Equipment storage facilities such as racks will be adequately secured to avoid unauthorized access.

A gate pass issued by an appointed IT member will follow the movement of IT equipment/assets to/from the XYZ TS premises. The data center manager will approve and verify the monthly review of asset movement.

Further, IT equipment/ media removed for disposal or re-use will follow the ***Media Handling and Disposal Procedure.***

The physical safety of personnel must always take precedence in any circumstance and should not be compromised in pursuit of any other policy objective.

XYZ TS must adhere to all health and safety rules and regulations imposed by the Government and other applicable regulatory bodies.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

9. Main Responsibilities

The following table illustrates the control owners for controls related to the physical and environmental security of the XYZ Holdings premises.

Control	Maintenance Frequency	Control Types	Responsible Team
Access Control System of the XYZ TS Data Center / Premises	Quarterly	Physical Security	TecSecOps
Fire suppression system and firefighting equipment for Premises	Quarterly	Physical Security	Administration Team
Fire suppression system and firefighting equipment for Server Room	Quarterly	Environmental protection	Administration Team
AC system for premises	Once in four months	Environmental protection	Administration Head
AC system For Server Room	Once in four months	Environmental protection	Administration Team
Fire Drills	Annually	Environmental protection	Manager Administration

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

Uninterrupted Power Supply (UPS) for XYZ TS Server Room	Once in 4 months	Support utilities	Manager Administration
Generators	Vendor Maintenance – Annually	Generators	Administration Team

10. Power, Air-conditioning, and Other Supporting Utilities

To maintain warranty coverage, all IT equipment must be operated within the environmental conditions specified by the supplier, including power supply, humidity, ventilation, and temperature control.

XYZ TS's power supply system design should prioritize safety and uninterrupted operation. It must consider the power needs of fire suppression systems, air conditioning, and other critical equipment.

All critical IT systems (including servers, network equipment, and workstations) must have sufficient protection from power failures, including power loss, voltage anomalies, etc. Protection measures may include a combination of Uninterruptible Power Supply (UPS) devices and generators. The protection measures must be appropriate to each location's local main power supply conditions.

All XYZ TS power supply equipment must be tested and maintained regularly, as per the guidelines of the relevant equipment manufacturer. The safeguarding and maintenance of such equipment are the responsibility of the building maintenance.

Whenever IT equipment requires regulating air temperature (e.g., for servers), the air conditioning system in that area must be supplied with uninterruptible power.

The relevant process owners must regularly monitor environmental conditions affecting the proper functioning of the IT equipment (such as air temperature and humidity). If any adverse condition is detected, immediate steps must be taken to avoid data loss and system failure. When evaluating the environmental factors, the equipment and system suppliers' guidelines must be considered.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

11. Cabling Security

Network and power cabling should be protected from unauthorized interception and damage. Whenever possible, cabling must be made underground or within a secured housing.

Cable and equipment markings and naming should be identifiable and documented for reference and to avoid errors.

Cables must be color-coded according to industry standards and labeled to identify both ends easily. Whenever possible, utilize cable management systems in secure locations and ensure redundant pathways exist. Ideally, the associated service provider should furnish cabling diagrams and documentation.

12. Removal and Disposal of IT Equipment

Equipment used to support business activities outside XYZ TS must be subject to the same type of management authorization and security protection as on-site equipment.

Any IT equipment (workstations, peripherals, or storage media) removed from XYZ TS premises requires prior approval. A removal log must document the responsible person, approved timeframe, and reason for removal.

The Head of IT must approve removing data storage devices or equipment with data storage devices.

The Technology Services must ensure that all equipment removed from XYZ TS's custody for maintenance purposes is adequately secured and sanitized to prevent unauthorized access to information kept in such equipment.

IT equipment must be disposed of with approval from the IS Officer.

All equipment containing storage media (e.g., fixed hard drives) must be checked to ensure critical business information assets and licensed software are removed, securely overwritten, or destroyed before disposal, resale, or donation. The disposal and reuse of storage media will be handled by the Media Handling and Disposal Procedure.

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching

13. Information Security Management System Auditor

ISMSA will perform an ISMS Internal audit annually as part of their audit to ensure the following:

- Equipment is appropriately sited and secured.
- Racks/Cabinets are kept locked, and keys are appropriately secured.
- Cables are appropriately segregated, labeled, and secured; and
- Equipment will be labeled according to their classification.

The Information Security Management System Auditor (ISMSA) will ensure that the physical security perimeter of the XYZ Holdings premises is appropriately designed and that any identified threats are mitigated. These include wall and window construction and access-controlled doors on each floor to enter XYZ Holdings premises.

ISMSA will obtain the infrastructure maintenance records from the Administration Team and other maintenance records from the Administrative Head to ensure that periodic preventive maintenance/testing has been carried out appropriately and that corrective/preventive actions have been taken for any identified deficiency during the maintenance/testing.

If the periodic preventive maintenance/ testing has yet to be done at the planned frequency or any other exceptions are noted, ISMSA will report the exceptions in the internal/external audit report as non-conformities and highlight them to the Head of Infrastructure Support and Services.

14. Latest Version of This Document

You can obtain the latest version of this document from the Chief Digital Officer (CDO).

XYZ | Confidential - External

CS5292 W6 · D14 · sanitised for teaching